

Access Controls Policy

Owner: Bar Elezra, Head of Information Security
Contact: security@pennylime.com
Effective date: April 1, 2026
Last reviewed: April 29, 2026
Review cadence: Annual, or upon material change.
Public copy: <https://pennylime.com/security/access-controls>
Parent policy: Information Security Policy (<https://pennylime.com/security>)

This Access Controls Policy establishes the requirements for granting, managing, reviewing, and revoking access to PennyLime information systems, customer data, source code, infrastructure, and physical work environments. It is binding on all personnel, contractors, and service providers, and supplements the parent Information Security Policy.

1. Purpose and Scope

This policy applies to every system, application, and dataset that processes, stores, or transmits PennyLime information assets, including production application infrastructure (Railway, Cloudflare), source-code repositories (GitHub), administrative consoles, third-party vendor portals (Plaid, Twilio, Google Workspace), and any physical or remote work environments used by personnel.

2. Guiding Principles

- **Least privilege.** Personnel receive the minimum access required to perform their role.
- **Need to know.** Access to Restricted or Confidential data is granted only when a documented business purpose exists.
- **Separation of duties.** Sensitive operations (e.g., production deployments, customer data exports, financial disbursements) require two-person review where feasible.
- **Defense in depth.** Authentication, authorization, network controls, and audit logging operate independently as layered controls.

3. Roles and Responsibilities

Role	Responsibility
Head of Information Security	Owns this policy. Approves provisioning of privileged access. Conducts quarterly access reviews. Final authority on exceptions.
Founder / Executive Sponsor	Backup approver. Receives quarterly access-review summaries.
System Owners	Maintain user lists for systems they own. Notify the Head of InfoSec of role changes within one business day.

All Personnel	Comply with this policy. Report suspected unauthorized access to security@pennylime.com immediately.
---------------	--

4. Account Provisioning

Access is provisioned only after: (a) the user has acknowledged the Information Security Policy in writing; (b) a documented business need is approved by the Head of Information Security; and (c) the user has completed required onboarding security training. Access requests are recorded with date, requester, approver, scope of access, and business justification.

5. Authentication

- **Multi-factor authentication (MFA)** is required for all administrative and production-data accounts, including Railway, Cloudflare, GitHub, Google Workspace, Plaid, Twilio, and the PennyLime admin console.
- **Passwords** meet a minimum of 14 characters with complexity, are unique per system, and are stored only in an approved password manager. Reuse of passwords across systems is prohibited.
- **Session timeouts** are enforced at 12 hours of inactivity for administrative consoles and 30 minutes for sensitive customer-data views.
- **Shared accounts and shared credentials are prohibited.** Service accounts, where unavoidable, are individually owned, documented, and rotated quarterly.

6. Authorization and Role-Based Access Control (RBAC)

Application-level access is governed by named roles enforced in code. Current production roles include:

Role	Scope
SUPER_ADMIN	Full administrative access including user management, settings, and Restricted data fields.
ADMIN	Operational access (applications, payments, contacts) excluding system configuration.
UNDERWRITER	Read access to applications and supporting documents; write access to underwriting decisions.
SUPPORT	Read access to assigned contacts; ability to record notes and outreach activities.
READ_ONLY / AUDITOR	Read-only access for compliance review.

Role assignments are documented and reviewed quarterly. Role changes follow the same approval workflow as provisioning.

7. Privileged Access Management

Privileged access (production database, infrastructure root, payments processor) is restricted to named individuals listed in the Privileged Access Roster. Privileged actions are logged with actor, timestamp, action, and target. Privileged access is reviewed by the Head of InfoSec monthly.

8. Access Reviews

The Head of Information Security performs an access review at least **quarterly**. Each review confirms that every active account is still required, has the correct role, and has MFA enabled. Privileged access is reviewed monthly. Findings are tracked to remediation; out-of-policy access is removed within five business days.

9. Termination and De-provisioning

Access is revoked within **one business day** of separation, role change, contractor end-of-engagement, or any incident requiring immediate revocation. The de-provisioning checklist covers application accounts, source-code access, vendor portals, secrets-store credentials, single-sign-on entitlements, and physical or remote-work resources. Revocation is verified and documented.

10. Remote Access

Personnel access production systems exclusively over HTTPS / TLS 1.2+ with MFA. Access from public or untrusted networks requires a hardened personal device with full-disk encryption and current operating-system updates. VPN is used where additional network segregation is required.

11. Third-Party Access

Third-party access (vendors, contractors, auditors) is granted only with a written agreement that includes confidentiality, security, and breach-notification obligations. Access is time-limited to the engagement and reviewed at least quarterly. Vendors handling Restricted or Confidential data are listed in the Vendor Risk Register maintained by the Head of InfoSec.

12. Audit Logging and Monitoring

Authentication events, administrative actions, role changes, privileged actions, and access to Restricted or Confidential customer data are logged with a tamper-resistant audit trail retained for at least 12 months. Logs are reviewed periodically and on trigger events. Anomalous patterns (failed logins, after-hours access, bulk data export) trigger investigation.

13. Physical Access

PennyLime is a remote-first organization. Production infrastructure is hosted in third-party data centers operated by Railway and Cloudflare; their physical security controls are reviewed annually as part of vendor risk management. Personnel work from secured personal environments using encrypted, password-protected devices.

14. Exceptions

Exceptions to this policy are granted only by the Head of Information Security with documented business justification, compensating controls, and an expiration date. Active exceptions are reviewed at each access review.

15. Policy Review and Acknowledgment

This policy is reviewed at least annually, or upon material change to the business, technology stack, or regulatory environment. Personnel acknowledge this policy at hire and at each annual review.

